

Security+ 2.3 · Hardware Vulnerabilities

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.3** —
Hardware Vulnerabilities (6:27) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Hardware vulnerabilities target firmware (BIOS/UEFI — the hardware-OS interface); a compromised firmware is nearly invisible. EOL (End of Life) devices receive no patches — decommission or segment them. Legacy devices are old machines with exploitable vulnerabilities. Defenses: firmware patching, replace/segment EOL systems, air gap for critical assets.

High-Yield Core Concepts Tested on Exam

- Compromised firmware survives OS reinstallation
- EOL = no vendor support; segment or replace
- Legacy devices often lack modern security controls
- Air gap isolates critical systems from network attacks
- Firmware attacks can persist below the OS layer

Exam Tips & Classic Scenarios

- 'device cannot receive updates anymore' = EOL risk
- 'compromise persists after OS reinstall' = firmware compromise
- 'old printer exposed to internet without patches' = legacy/EOL device risk

Typical Exam Scenario: Scenario: 'an old factory printer cannot be patched and is exposed to the internet' = legacy/EOL device risk.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.3 — Hardware Vulnerabilities)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Compromising a software vendor to reach all of its customers (e.g., SolarWinds):

- A)** Supply chain attack
- B)** Watering hole
- C)** Insider
- D)** Zero-day

2. Corporate scenario (Hardware Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Compromised firmware survives OS reinstallation'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Compromised firmware survives OS reinstallation...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

3. Corporate scenario (Hardware Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'EOL = no vendor support; segment/replace'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: EOL = no vendor support; segment/replace...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

4. Corporate scenario (Hardware Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'device cannot receive updates anymore' = EOL risk. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'device cannot receive updates anymore' = EOL risk...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Hardware Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'compromise persists after OS reinstall' = firmware compromise'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'compromise persists after OS reinstall' = firmware compromise...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Hardware Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Scenario: 'old factory printer cannot be patched and is exposed to the internet' = legacy/EOL device risk.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Scenario: 'old factory printer cannot be patched and is exposed to the internet' = legacy/EOL device risk...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Hardware Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Compromised firmware survives OS reinstallation.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Compromised firmware survives OS reinstallation...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Hardware Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'EOL = no vendor support; segment/replace'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: EOL = no vendor support; segment/replace.
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Hardware Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: "device cannot receive updates anymore" = EOL risk'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'device cannot receive updates anymore' = EOL risk...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Hardware Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: "compromise persists after OS reinstall" = firmware compromise.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'compromise persists after OS reinstall' = firmware compromise...

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — Supply chain attack.

✓ **Why it is correct:** A supply chain attack occurs when an adversary compromises a vendor, partner, or software/hardware component to reach the end customers of that vendor. In the SolarWinds case (2020), attackers compromised the build process of the Orion software, inserting malicious code that was distributed as a legitimate update to thousands of customers, including government agencies. This is the classic example of a supply chain attack, as described in SY0-701 objective 2.2 (supply chain threats) and 2.3 (attack vectors). The question describes exactly this scenario: compromising a software vendor to reach all of its customers.

✗ **Why the others are wrong:**

- *Watering hole:* A watering hole is an attack in which the adversary compromises a legitimate website frequented by a specific group of victims (e.g., an industrial sector site) and inserts malicious code to infect visitors. The goal is to reach users who visit that site, not to compromise a software vendor to distribute malware to all its customers. In a watering hole, the vector is the third-party site visited by victims; in a supply chain attack, the vector is the vendor's own product or update. The question speaks of compromising a software vendor to reach all its customers, which is supply chain, not watering hole.
- *Insider:* An insider threat refers to an individual with authorized access (employee, contractor, partner) who uses that access to cause harm, steal data, or facilitate attacks. The attacker is internal to the organization, not a compromised external vendor. In the SolarWinds case, the attackers were external (APT29) who compromised SolarWinds' supply chain; it is not an insider of SolarWinds or its customers. Therefore, insider does not describe the scenario of compromising a vendor to reach its customers.
- *Zero-day:* A zero-day refers to a vulnerability unknown to the vendor, for which no patch is available. The attack exploits this flaw before it is fixed. Although supply chain attacks may involve zero-days, the concept of zero-day is about the nature of the vulnerability, not about the vector of compromising a vendor to reach customers. In the SolarWinds case, the attack did not rely exclusively on a zero-day; it involved compromising the build process and distributing a malicious update. The question asks for the name of the attack that compromises a vendor to reach all customers, which is supply chain, not zero-day.

2) A — Implement the corresponding solution: Compromised firmware survives OS reinstallation....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Hardware Vulnerabilities): Compromised firmware survives OS reinstallation. Firmware resides on hardware components and persists across operating system reinstalls, making firmware attacks stealthy and difficult to remediate without specialized tools or hardware replacement.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

3) B — Implement the corresponding solution: EOL = no vendor support; segment/replace....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Hardware Vulnerabilities): EOL = no vendor support; segment/replace. End-of-life hardware no longer receives security updates, making it vulnerable. Mitigations include network segmentation to isolate the device or replacement with supported hardware.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who made critical changes or executed malicious commands.

4) B — Implement the corresponding solution: 'device cannot receive updates anymore' = EOL risk....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Hardware Vulnerabilities): 'device cannot receive updates anymore' = EOL risk. End-of-life (EOL) hardware no longer receives security patches or vendor support, making it vulnerable to known exploits and compliance violations.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) A — Implement the corresponding solution: 'compromise persists after OS reinstall' = firmware compromise....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Hardware Vulnerabilities): 'compromise persists after OS reinstall' = firmware compromise. Firmware-level compromises, such as rootkits in UEFI/BIOS, survive OS reinstallation because they reside below the operating system. Detection and remediation require firmware updates, hardware replacement, or specialized tools.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* This destroys individual

accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: Scenario: 'old factory printer cannot be patched and is exposed to the internet' = legacy/EOL device risk....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Hardware Vulnerabilities): Scenario: 'old factory printer cannot be patched and is exposed to the internet' = legacy/EOL device risk. Legacy or end-of-life devices no longer receive security updates, making them vulnerable to exploits.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: Compromised firmware survives OS reinstallation....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Hardware Vulnerabilities): Compromised firmware survives OS reinstallation. Firmware resides on hardware components and can be infected with persistent malware that remains even after the operating system is reinstalled, requiring firmware updates or hardware replacement.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: EOL = no vendor support; segment/replace..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Hardware Vulnerabilities): EOL = no vendor support; segment/replace. End-of-life hardware no longer receives security patches, so compensating controls such as network segmentation or full replacement are required to reduce exposure.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and it breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks,

injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: 'device cannot receive updates anymore' = EOL risk....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Hardware Vulnerabilities): 'device cannot receive updates anymore' = EOL risk. End-of-Life (EOL) refers to the point when a hardware or software product is no longer supported by the vendor, meaning no more security patches, firmware updates, or technical support. This creates a significant risk because newly discovered vulnerabilities will remain unpatched. The correct control is to inventory EOL assets, assess risk, and plan for replacement or compensating controls.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) D — Implement the corresponding solution: 'compromise persists after OS reinstall' = firmware compromise....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Hardware Vulnerabilities): A firmware compromise persists even after reinstalling the operating system, as the malicious code resides in the firmware layer, requiring firmware updates or hardware replacement to remediate.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.